

AWS Basics and IAM

Acharya Coding School



Key Features:

1. On-demand Access

2. Scalability

3. Pay-as-you-go

4. Accessibility

1. Traditional IT infrastructure Vs Cloud.

NGDC – Next generation Data center



2. Cloud service Model: IaaS, PaaS, SaaS



3. Deployment Models:

Public Cloud –
AWS, Azure, GCP.

Private Cloud –
Telstra

Hybrid Cloud

- Global Infrastructure:

- Regions – example; Hyderabad (Ap-south-2)
- Availability Zones - Small Datacenter
- Edge Locations - Srilanka – (No AWS presence in Srilanka) - Latency

List of Services (To be learnt in given flow for better understanding

Step 1: Foundations of Identity & Networking

- AWS IAM (Identity and Access Management)
- AWS VPC (Virtual Private Cloud)
- AWS Security Groups

Step 2: Core Compute & Storage

- AWS EC2 (Elastic Compute Cloud)
- AWS S3 (Simple Storage Service)

Step 3: Scaling & Availability

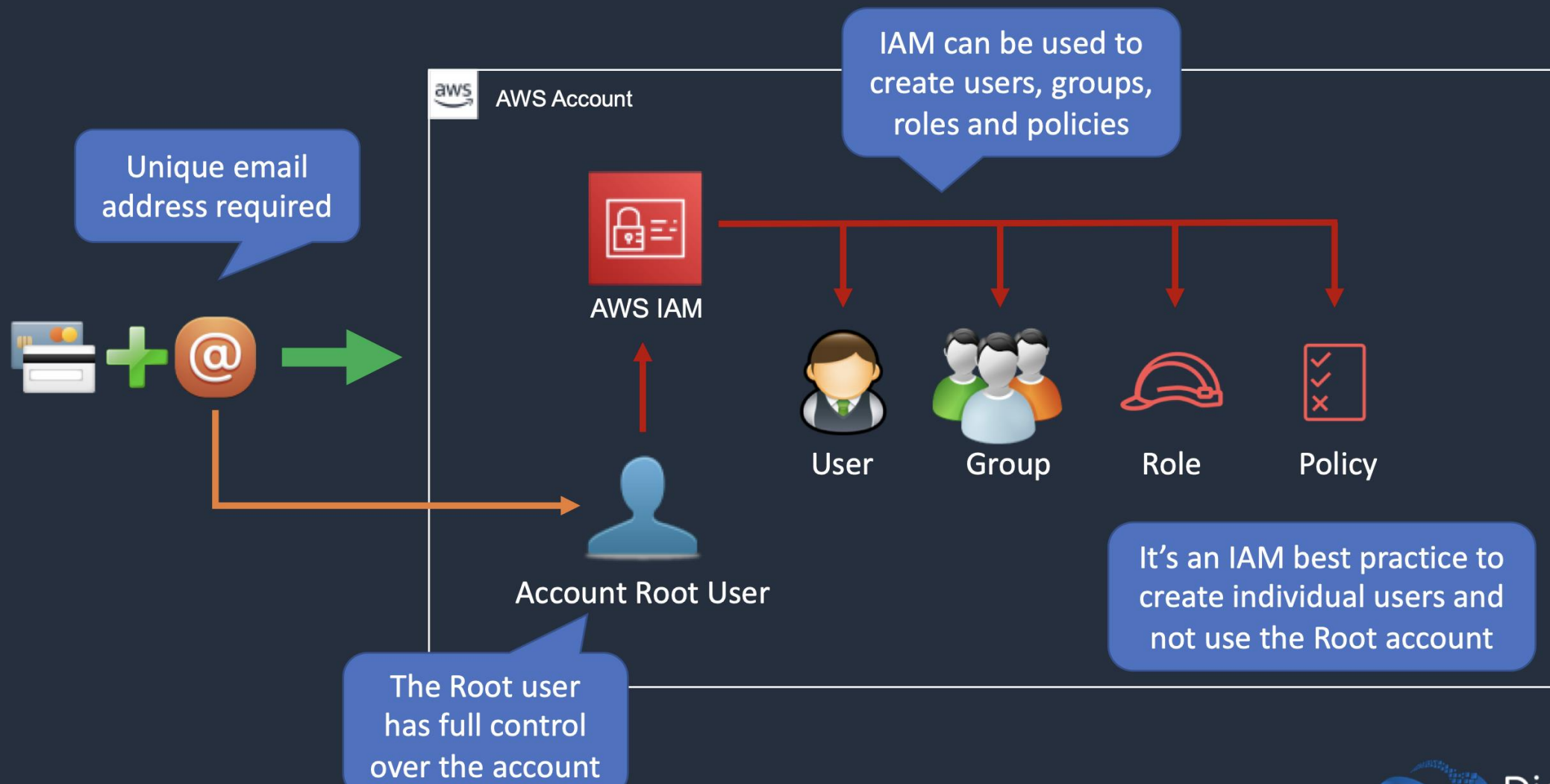
- AWS Load Balancing (Elastic Load Balancer)

Step 4: Application Deployment & Orchestration

- AWS Elastic Beanstalk
- AWS ECS (Elastic Container Service)
- AWS EKS (Elastic Kubernetes Service)

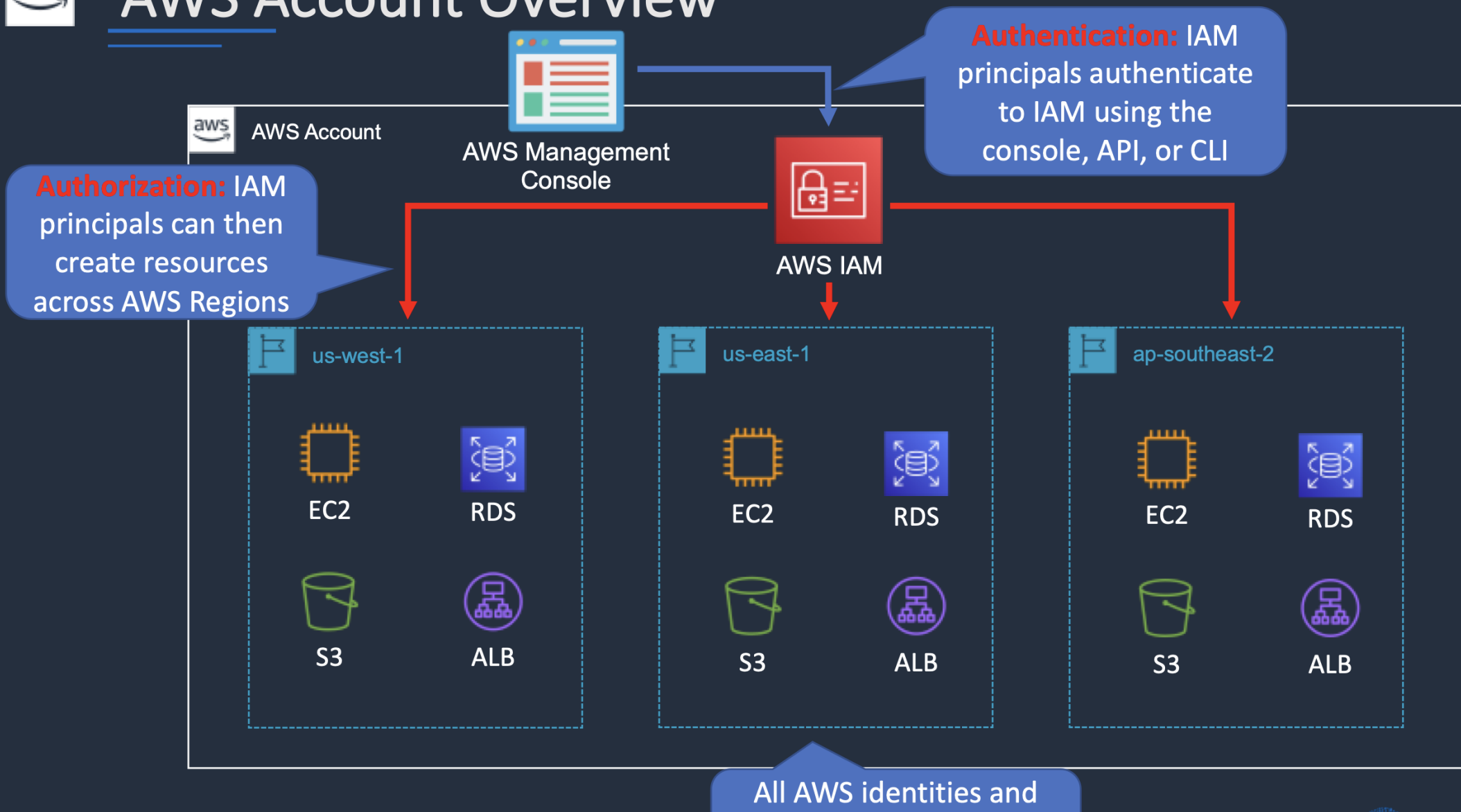


AWS Account Overview





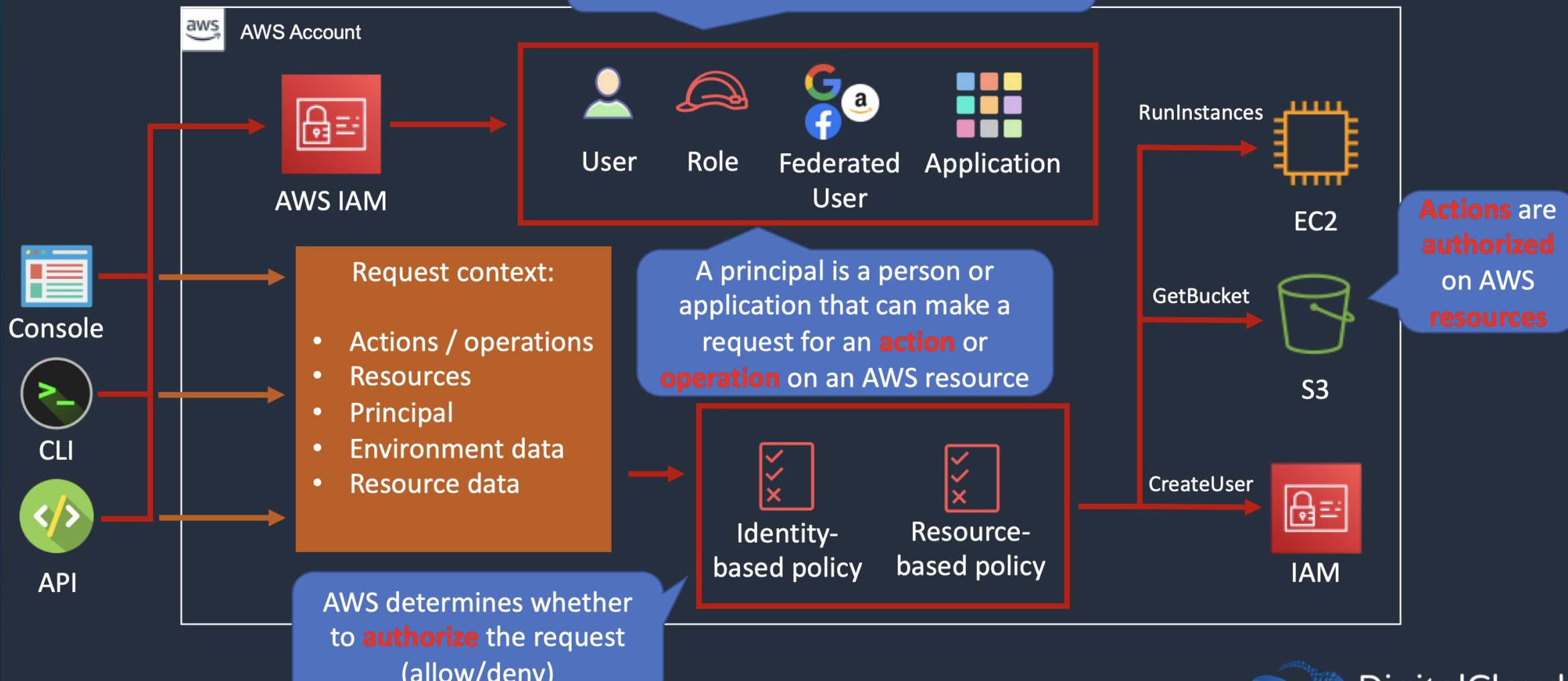
AWS Account Overview





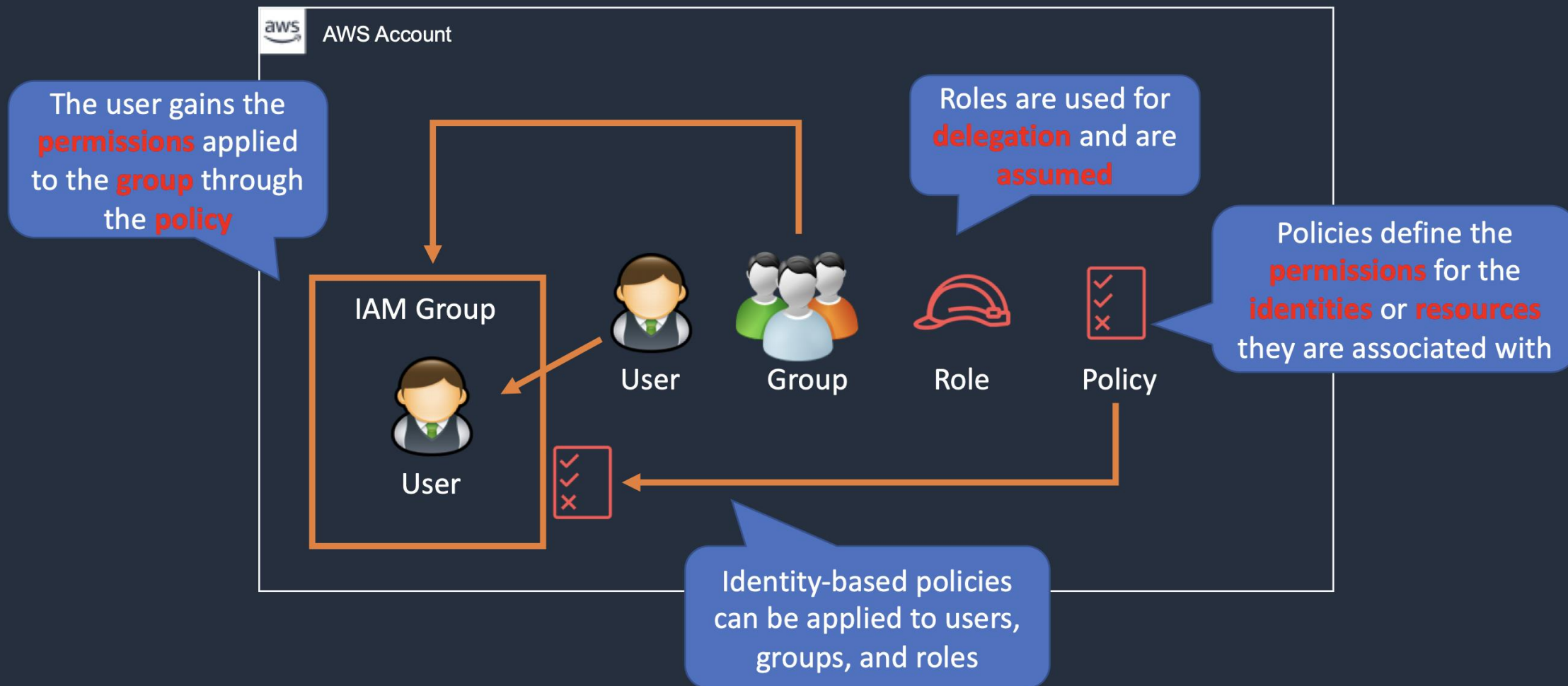
How IAM Works

IAM Principals must be **authenticated** to send requests (with a few exceptions)



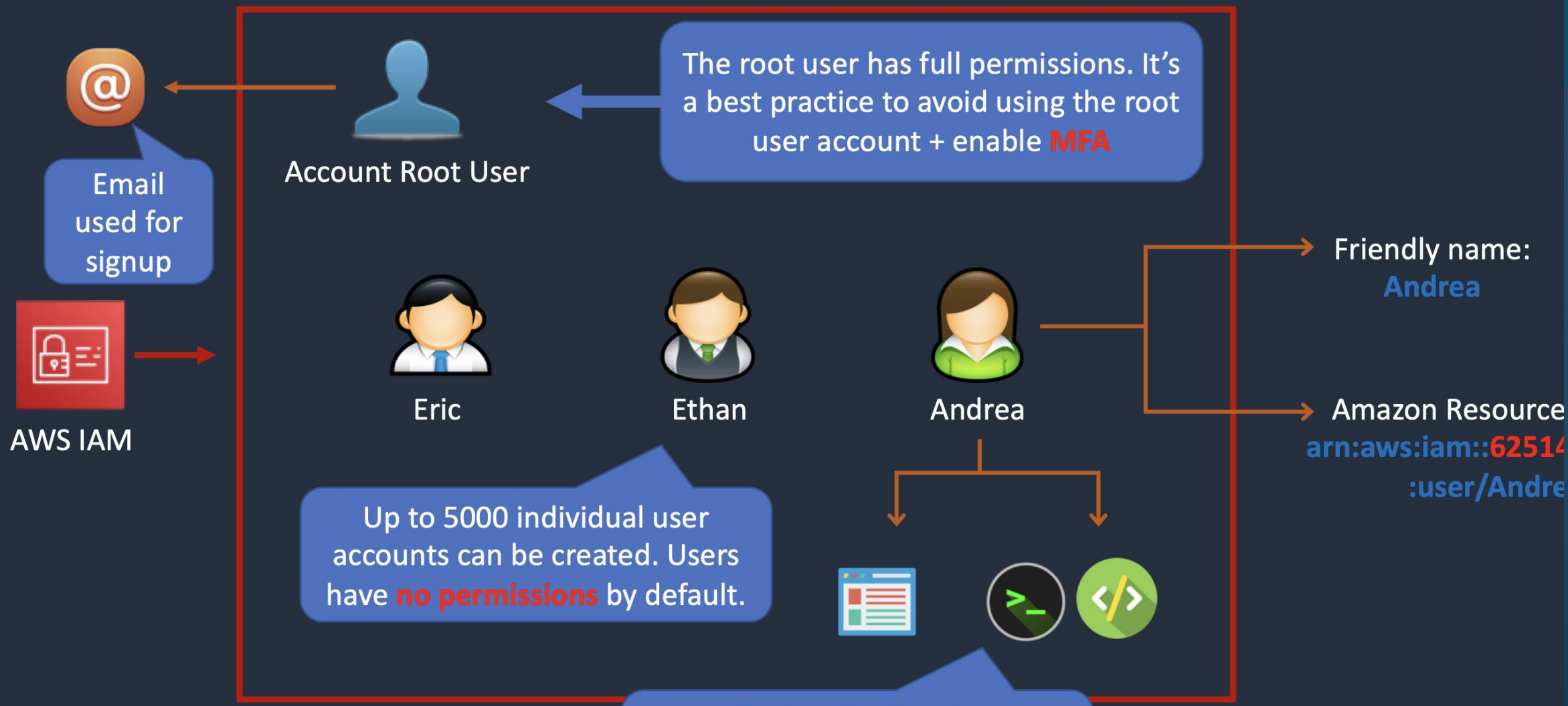


Users, Groups, Roles and Policies





IAM Users





IAM Groups



The user gains the **permissions** applied to the **group** through the **policy**

Groups are collections of users. Users can be members of up to 10 groups



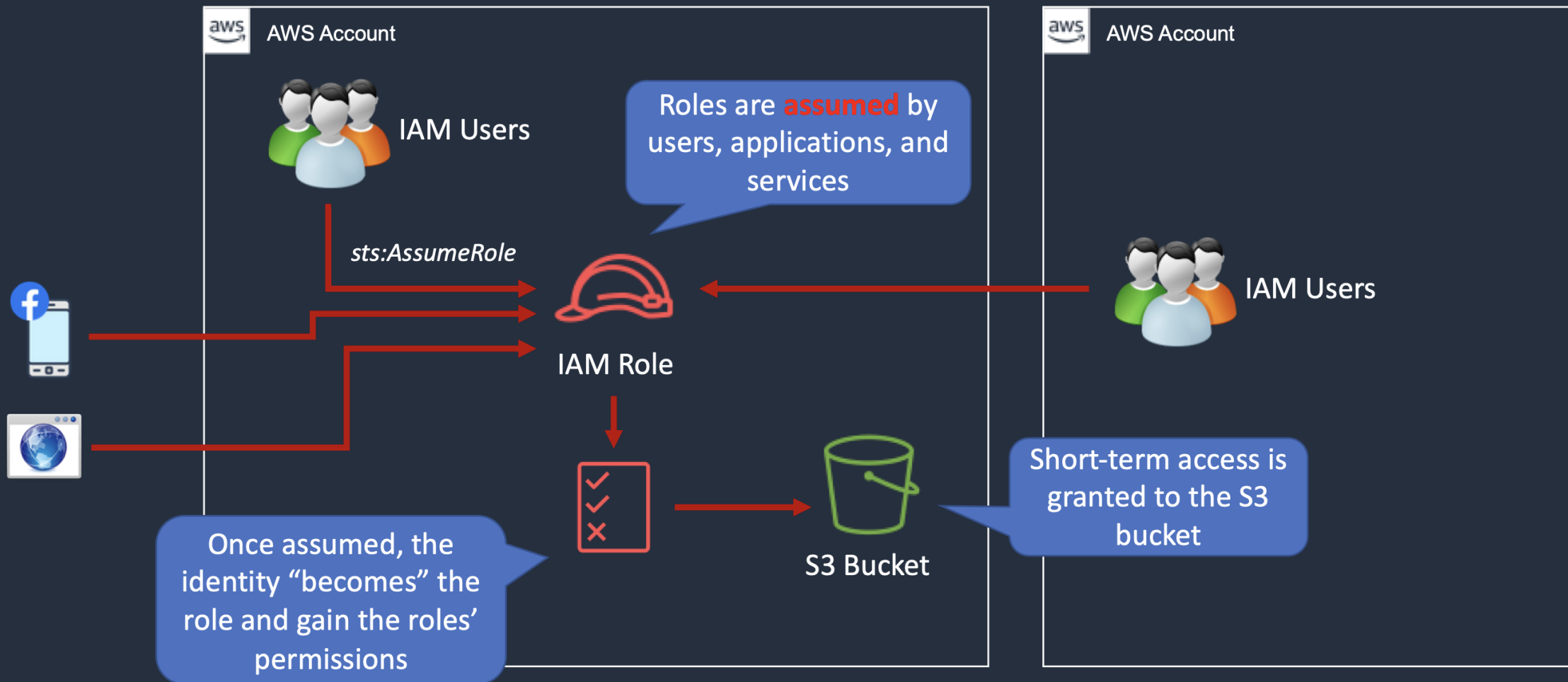
The main reason to use groups is to apply **permissions** to





IAM Roles

An IAM role is an IAM identity that has specific permissions





IAM Policies

Policies are documents that define permissions and are written in JSON



AdministratorAccess

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*"
    }
  ]
}
```

All permissions are implicitly denied by default



User



Group



Role

Identity-based policies can be applied to users, groups, and roles



Bucket Policy

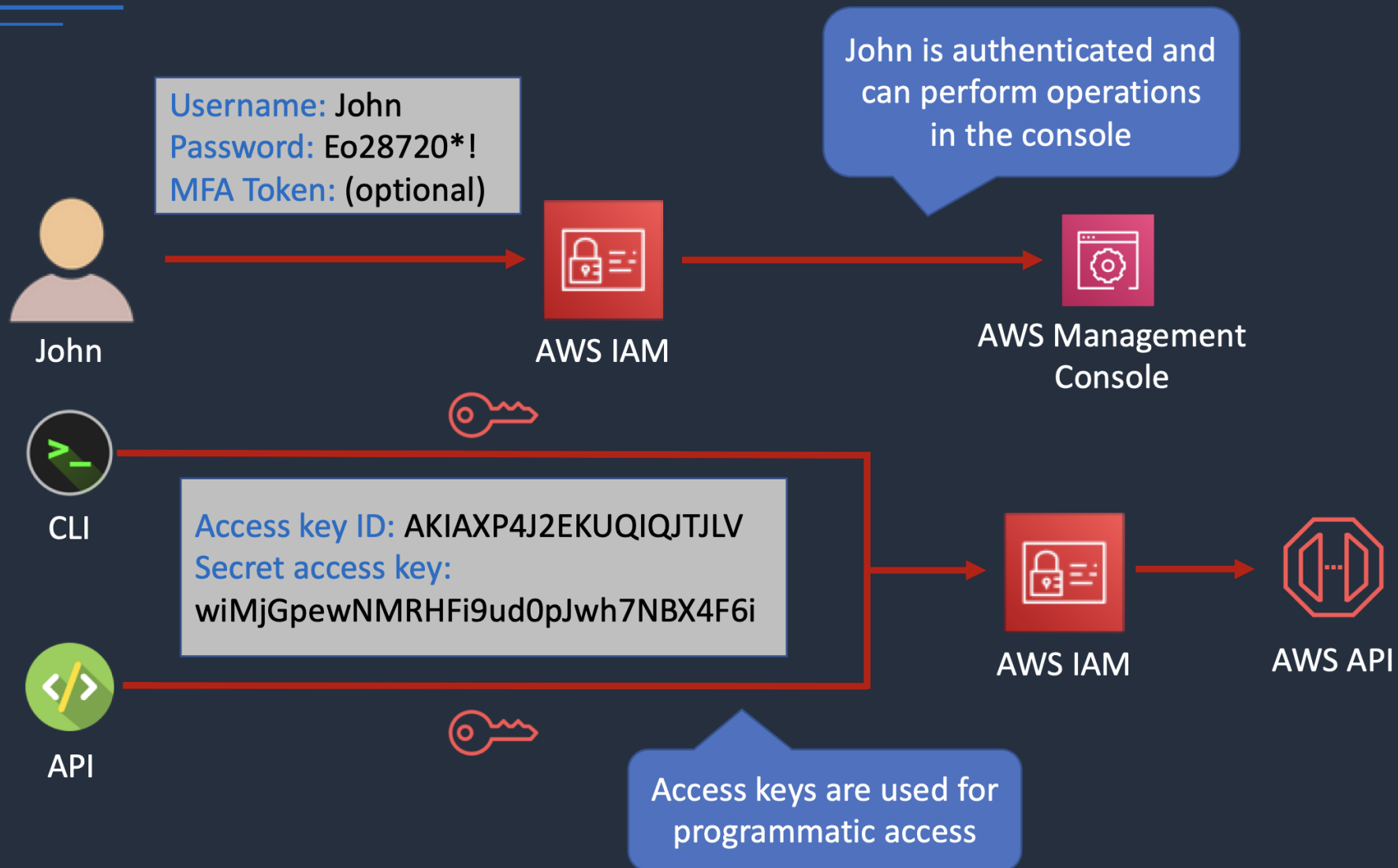


```
{
  "Version": "2012-10-17",
  "Id": "Policy1561964929358",
  "Statement": [
    {
      "Sid": "Stmt1561964454052",
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::515148227241:user/Paul"
      },
      "Action": "s3:*",
      "Resource": "arn:aws:s3:::dctcompany",
      "Condition": {
        "StringLike": {
          "s3:prefix": "Confidential/*"
        }
      }
    }
  ]
}
```

Resource-based policies apply to resources such as S3 buckets or DynamoDB tables

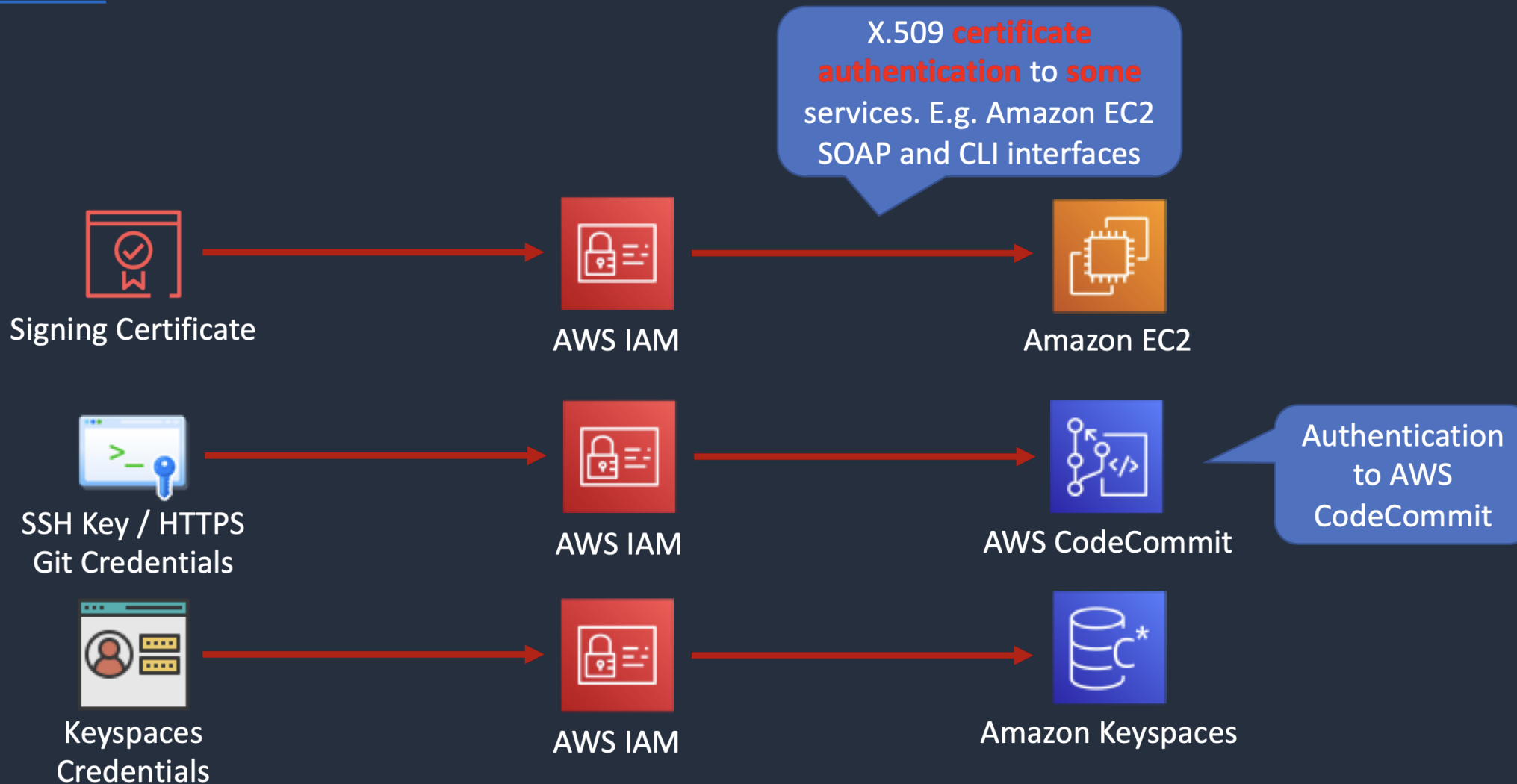


IAM Authentication Methods





IAM Authentication Methods





- Install Tools (AWS CLI and VS Code)

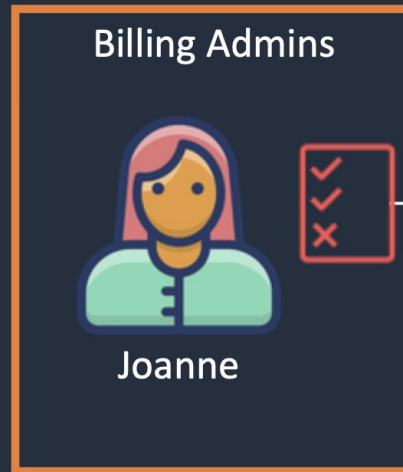


Role-Based Access Control (RBAC)

Job function policies:

- Administrator
- Billing
- Database administrator
- Data scientist
- Developer power user
- Network administrator
- Security auditor
- Support user
- System administrator
- View-only user

The Billing managed policy is attached to the group

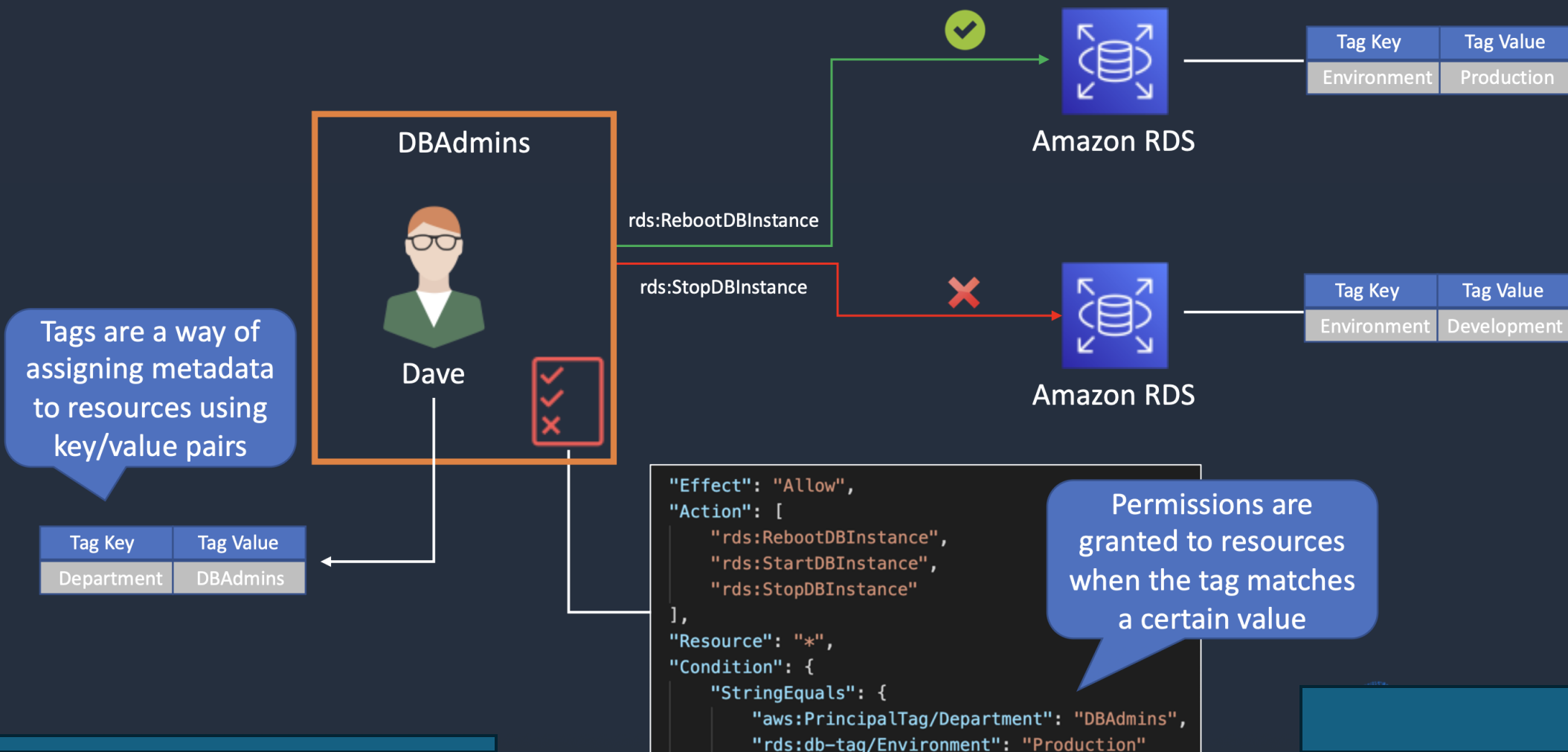


AWS managed policies for job functions are designed to closely align to common job functions in the IT industry

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "aws-portal:*Billing",
        "aws-portal:*Usage",
        "aws-portal:*PaymentMethods",
        "budgets:ViewBudget",
        "budgets:ModifyBudget",
        "ce:UpdatePreferences",
        "ce:CreateReport",
        "ce:UpdateReport",
        "ce>DeleteReport",
        "ce:CreateNotificationSubscription",
        "ce:UpdateNotificationSubscription",
        "ce>DeleteNotificationSubscription",
        "cur:DescribeReportDefinitions",
        "cur:PutReportDefinition",
        "cur:ModifyReportDefinition",
        "cur>DeleteReportDefinition",
        "purchase-orders:*PurchaseOrders"
      ],
      "Resource": "*"
    }
  ]
}
```



Attribute-Based Access Control (ABAC)





Privilege Escalation

IAMFullAccess



Lindsay

Lindsay is assigned permissions to AWS IAM only and cannot launch AWS resources

iam:CreateUser



IAM

Lindsay applies the AdministratorAccess policy to the X-User account

AdministratorAccess



X-User

Lindsay is now able to login with the X-User account and gain full privileges to the AWS account



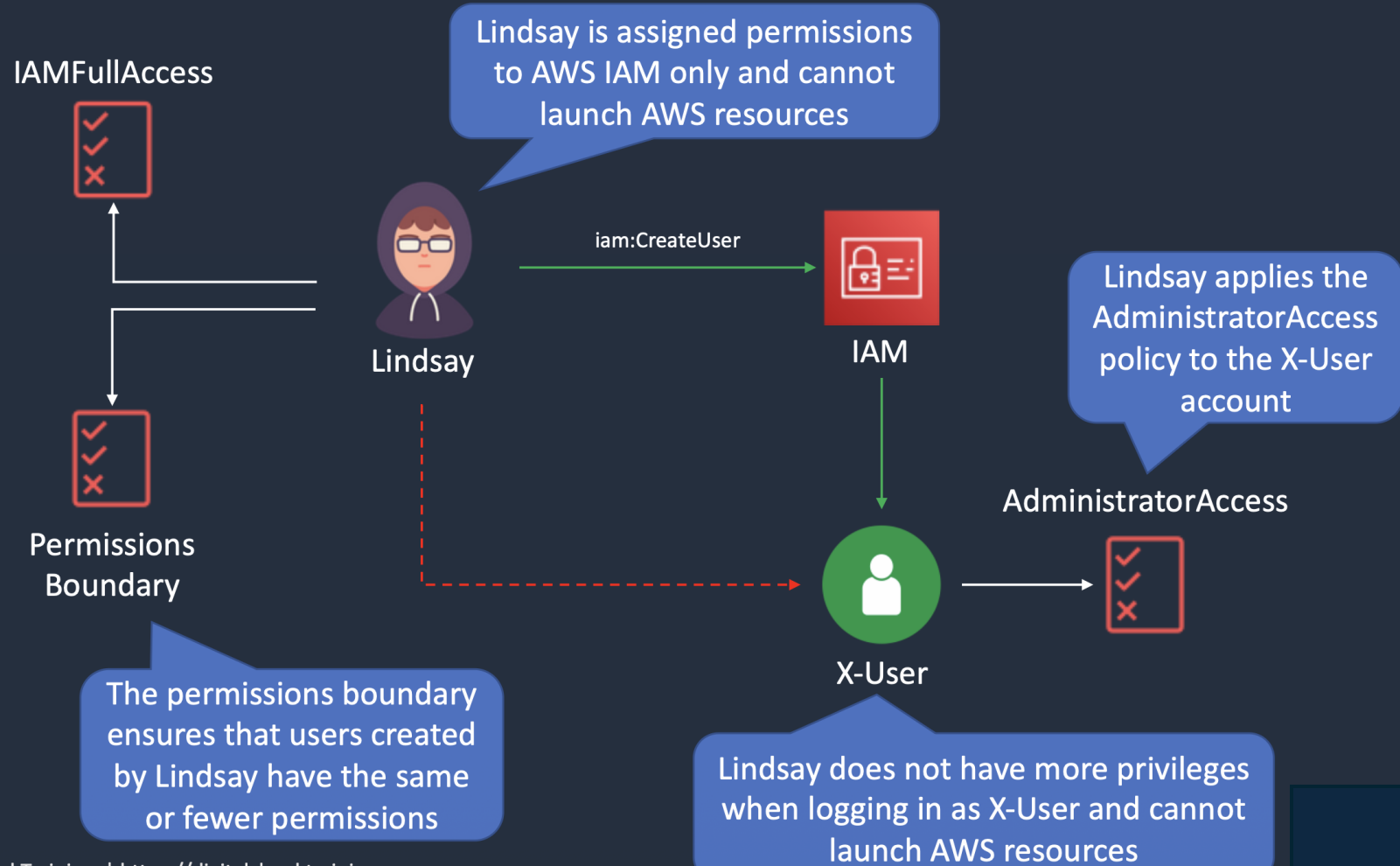
AWS Batch

Lindsay mines bitcoins





Preventing Privilege Escalation

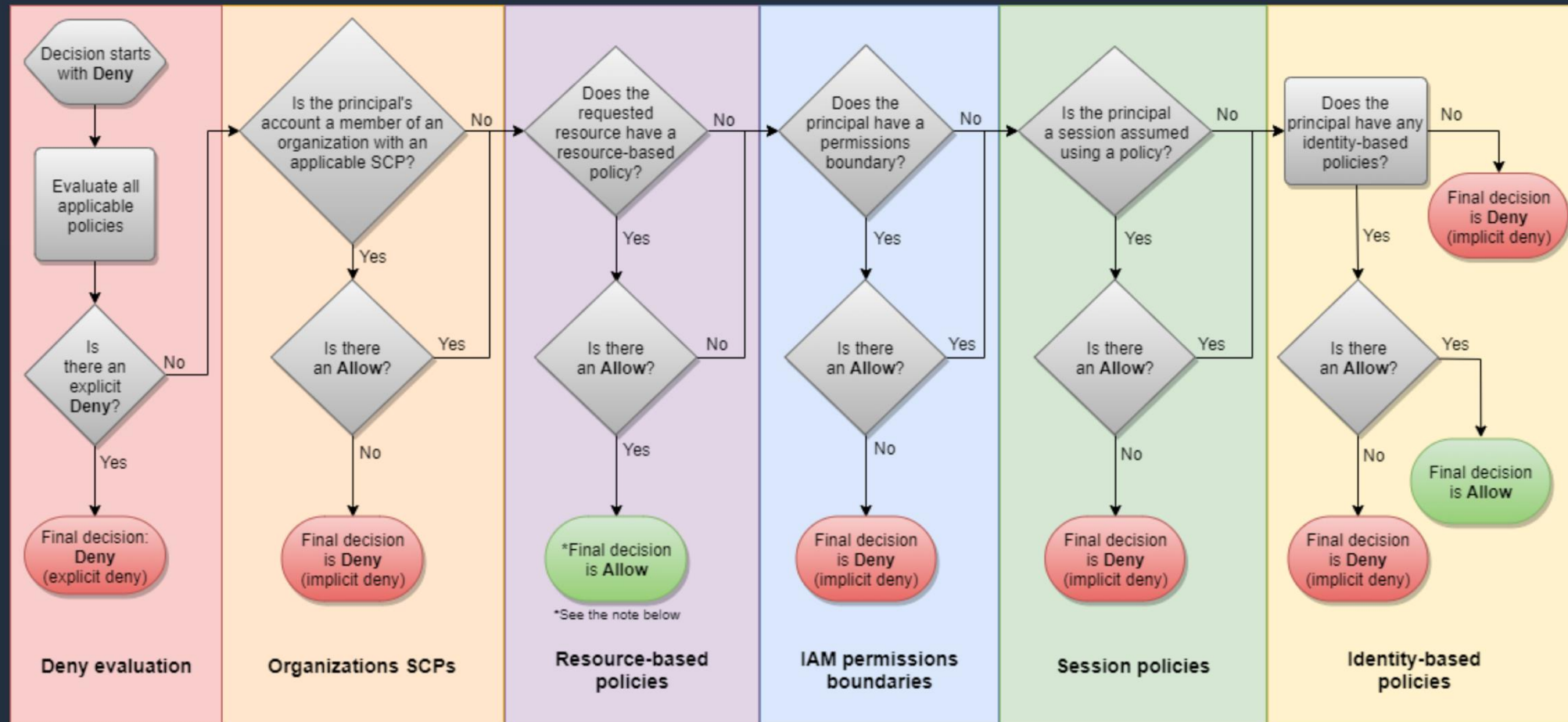


IAM Policy Evaluation Logic





Evaluation Logic



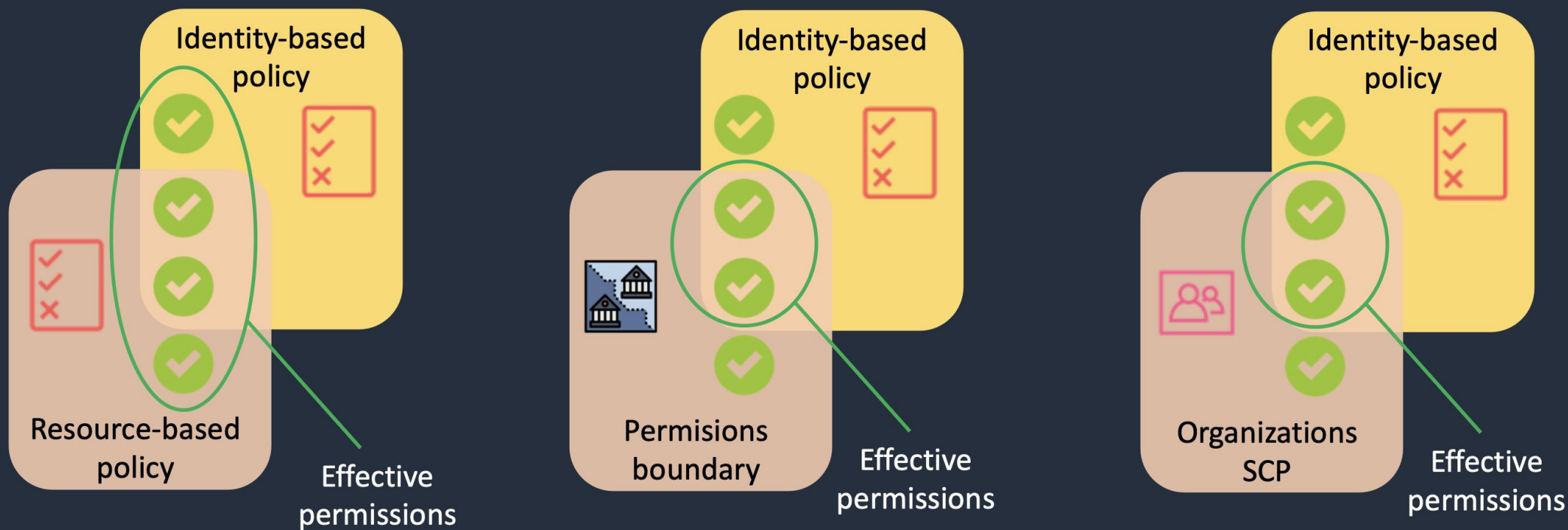


Types of Policy

- **Identity-based policies** – attached to users, groups, or roles
- **Resource-based policies** – attached to a resource; define permissions for a principal accessing the resource
- **IAM permissions boundaries** – set the maximum permissions an identity-based policy can grant an IAM entity
- **AWS Organizations service control policies (SCP)** – specify the maximum permissions for an organization or OU
- **Session policies** – used with AssumeRole* API actions



Evaluating Policies within an AWS Account





Determination Rules

1. By default, all requests are implicitly denied (though the root user has full access)
2. An explicit allow in an identity-based or resource-based policy overrides this default
3. If a permissions boundary, Organizations SCP, or session policy is present, it might override the allow with an implicit deny
4. An explicit deny in any policy overrides any allows

- **AWS Policy Generator**

<https://awspolicygen.s3.amazonaws.com/policygen.html>

- **IAM Policy Simulator**

<https://policysim.aws.amazon.com/home/index.jsp?#users>



IAM Policy Example 1

```
{  
  "Version": "2012-10-17",  
  "Statement": [  
    {  
      "Effect": "Allow",  
      "Action": "*",  
      "Resource": "*"  
    }  
  ]  
}
```

The AdministratorAccess policy uses wildcards (*) to allow all actions on all resources



IAM Policy Example 2

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": ["ec2:TerminateInstances"],
      "Resource": ["*"]
    },
    {
      "Effect": "Deny",
      "Action": ["ec2:TerminateInstances"],
      "Condition": {
        "NotIpAddress": {
          "aws:SourceIp": [
            "192.0.2.0/24",
            "203.0.113.0/24"
          ]
        }
      },
      "Resource": ["*"]
    }
  ]
}
```

The specific API action is defined

The effect is to deny the API action if the IP address is not in the specified range



IAM Policy Example 3

```
{
  "Version": "2012-10-17",
  "Id": "ExamplePolicy01",
  "Statement": [
    {
      "Sid": "ExampleStatement01",
      "Effect": "Allow",
      "Principal": {
        "AWS": "*"
      },
      "Action": [
        "elasticfilesystem:ClientRootAccess",
        "elasticfilesystem:ClientMount",
        "elasticfilesystem:ClientWrite"
      ],
      "Condition": {
        "Bool": {
          "aws:SecureTransport": "true"
        }
      }
    }
  ]
}
```

You can tell this is a resource-based policy as it has a principal element defined

The policy grants read and write access to an EFS file systems to all IAM principals ("AWS": "*")

Additionally, the policy condition element requires that SSL/TLS encryption is used



IAM Policy Example 4

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": ["s3:ListBucket"],
      "Effect": "Allow",
      "Resource": ["arn:aws:s3:::mybucket"],
      "Condition": {"StringLike": {"s3:prefix": ["${aws:username}/*"]}}
    },
    {
      "Action": [
        "s3:GetObject",
        "s3:PutObject"
      ],
      "Effect": "Allow",
      "Resource": ["arn:aws:s3:::mybucket/${aws:username}/*"]
    }
  ]
}
```

A variable is used for the s3:prefix that is replaced with the user's friendly name

The actions are allowed only within the user's folder within the bucket



IAM Access Analyzer

- AWS IAM Access Analyzer helps you identify the resources in your organization and accounts that are **shared** with an **external** entity

Access Analyzer analyzes the following resource types:



Amazon Simple Storage Service buckets



AWS Identity and Access Management roles



AWS Key Management Service keys



AWS Lambda functions and layers



Amazon Simple Queue Service queues

Amazon EC2 Instance Profile





Attach Role to EC2 Instance

